

GRC103 Lab: Practical Risk Monitoring with Wazuh

Course: GRC103 - Risk Assessment and Management Techniques

Module: Practical Risk Assessment Workshop

NAME: JOY ORILADE

DATE: 29TH APRIL, 2026

INSTRUCTOR: COMM IDRIS AMINU

Table of Contents

- 1. Lab Overview & GRC Learning Objectives**
- 2. Scenario: A Governance and Risk Mandate**
- 3. Lab Architecture**
- 4. Prerequisites**
- 5. Part 1: Deploying the Wazuh Manager (Ubuntu)**
- 6. Part 2: Accessing the Wazuh Dashboard**
- 7. Part 3: Installing the Wazuh Agent (Windows)**
- 8. Part 4: Agent-Manager Registration**
- 9. Part 5: Implementing a Detective Control (File Integrity Monitoring)**
- 10. Part 6: Risk Monitoring & Control Verification**
- 11. GRC Workshop & Analysis Questions**

1. Lab Overview & GRC Learning Objectives

Welcome, GRC Analysts! This hands-on workshop bridges the gap between risk theory and practice. You will deploy a technical control (Wazuh) to actively monitor an IT asset for a specific risk, unauthorized file changes, demonstrating how technical tools feed into the risk management lifecycle.

By the end of this lab, you will be able to:

- **Operationalize** a risk treatment by deploying a **detective control**.
- **Identify** a specific IT risk (unauthorized file modification) and configure a tool to monitor for it.
- **Analyze** and **evaluate** security events based on risk severity and potential business impact.
- **Demonstrate** the process of risk monitoring and control effectiveness reporting using a central dashboard.

- **Articulate** the value of centralized monitoring for governance and compliance reporting.

2. Scenario: A Governance and Risk Mandate

You are a GRC analyst. A recent risk assessment identified the **unauthorized modification or deletion of sensitive financial forecast documents** as a medium-to-high risk to the organization. The Risk Treatment Plan approved the implementation of a **detective control** to monitor this activity.

Your task is to implement a solution that can:

1. Continuously monitor a designated folder (C:\Users\<YourName>\SensitiveFiles) on a key user's workstation.
2. Detect and log any creation, modification, or deletion of files within that folder.
3. Provide a centralized audit trail and real-time alerting to demonstrate the control's operation for compliance and monitoring purposes.

You have selected the open-source Wazuh platform to fulfill this requirement.

3. Lab Architecture

Component	Host	GRC Role
Wazuh Manager	Ubuntu (VirtualBox)	The Risk Monitoring Platform . Aggregates and analyzes data for reporting.
Wazuh Agent	Windows (Host Machine)	The Control Agent . Installed on the asset (endpoint) being monitored.

Network Configuration:

- Set your Ubuntu VM's network adapter to **Bridged Adapter**. This places it on the same network as your host machine, allowing them to communicate.

4. Prerequisites

- VirtualBox installed.
- Ubuntu Server 20.04+ installed in VirtualBox (with bridged networking enabled).
- Internet access on the Ubuntu VM.

- Administrative access on your Windows host machine.

5. Part 1: Deploying the Wazuh Manager (Ubuntu)

Run the following steps on your Ubuntu VirtualBox server via a terminal window.

1. Add Wazuh GPG Key

bash

```
curl -s https://packages.wazuh.com/key/GPG-KEY-WAZUH | sudo gpg --dearmor -o /usr/share/keyrings/wazuh-archive-keyring.gpg
```

2. Download and Execute Installation Script

bash

```
curl -sO https://packages.wazuh.com/4.12/wazuh-install.sh && sudo bash ./wazuh-install.sh -a -i
```

- -a: Installs **all** components.
- -i: Runs in **interactive** mode (follow any on-screen prompts).

GRC Note: In a production environment, the separation of these components would be a key **compensating control** to mitigate the risk of a single point of failure.

Wazuh Management Commands

```
sudo systemctl restart wazuh-manager
```

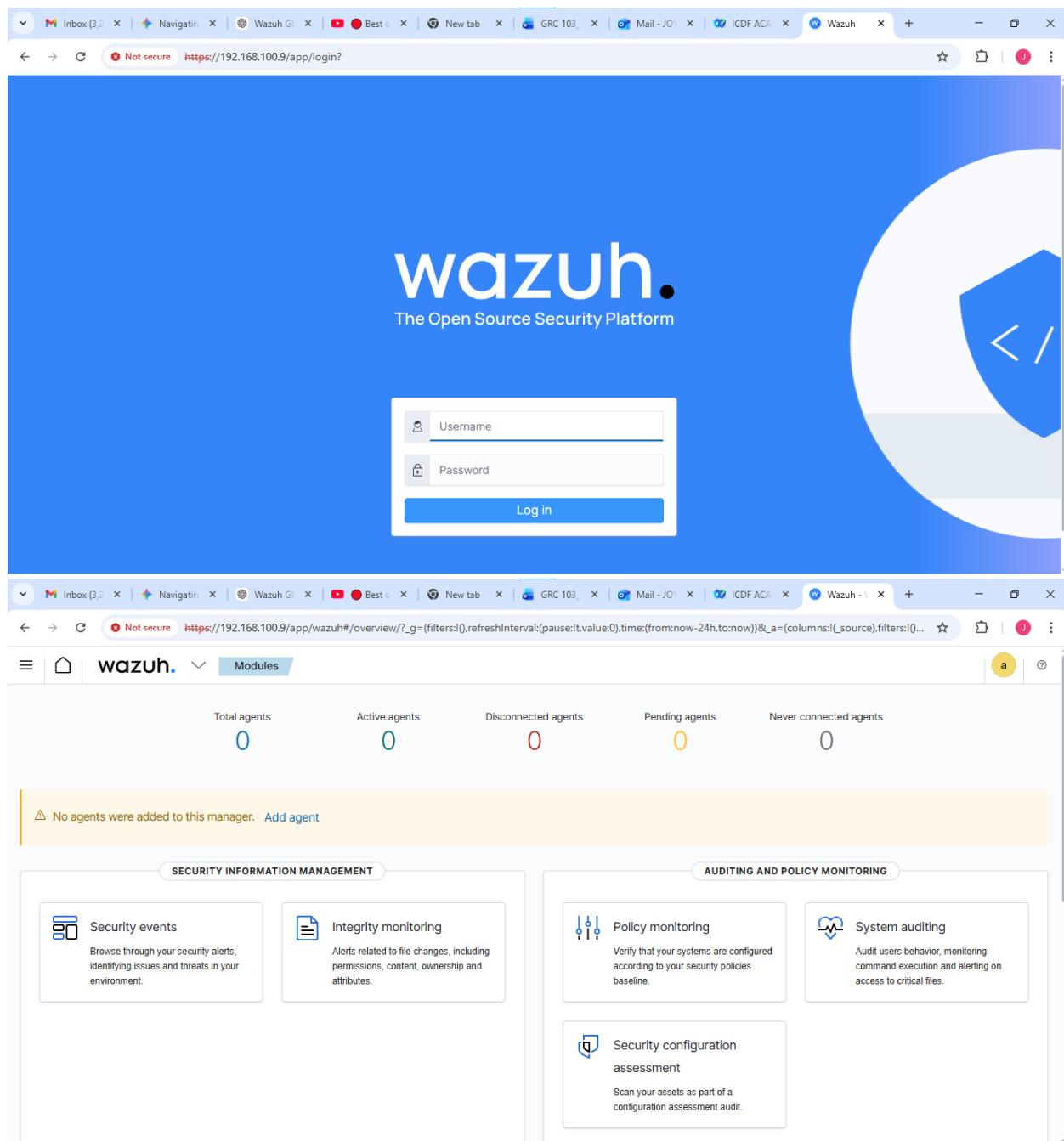
```
sudo systemctl stop wazuh-manager
```

```
sudo systemctl start wazuh-manager
```

```
sudo systemctl status wazuh-manager
```

6. Part 2: Accessing the Wazuh Dashboard

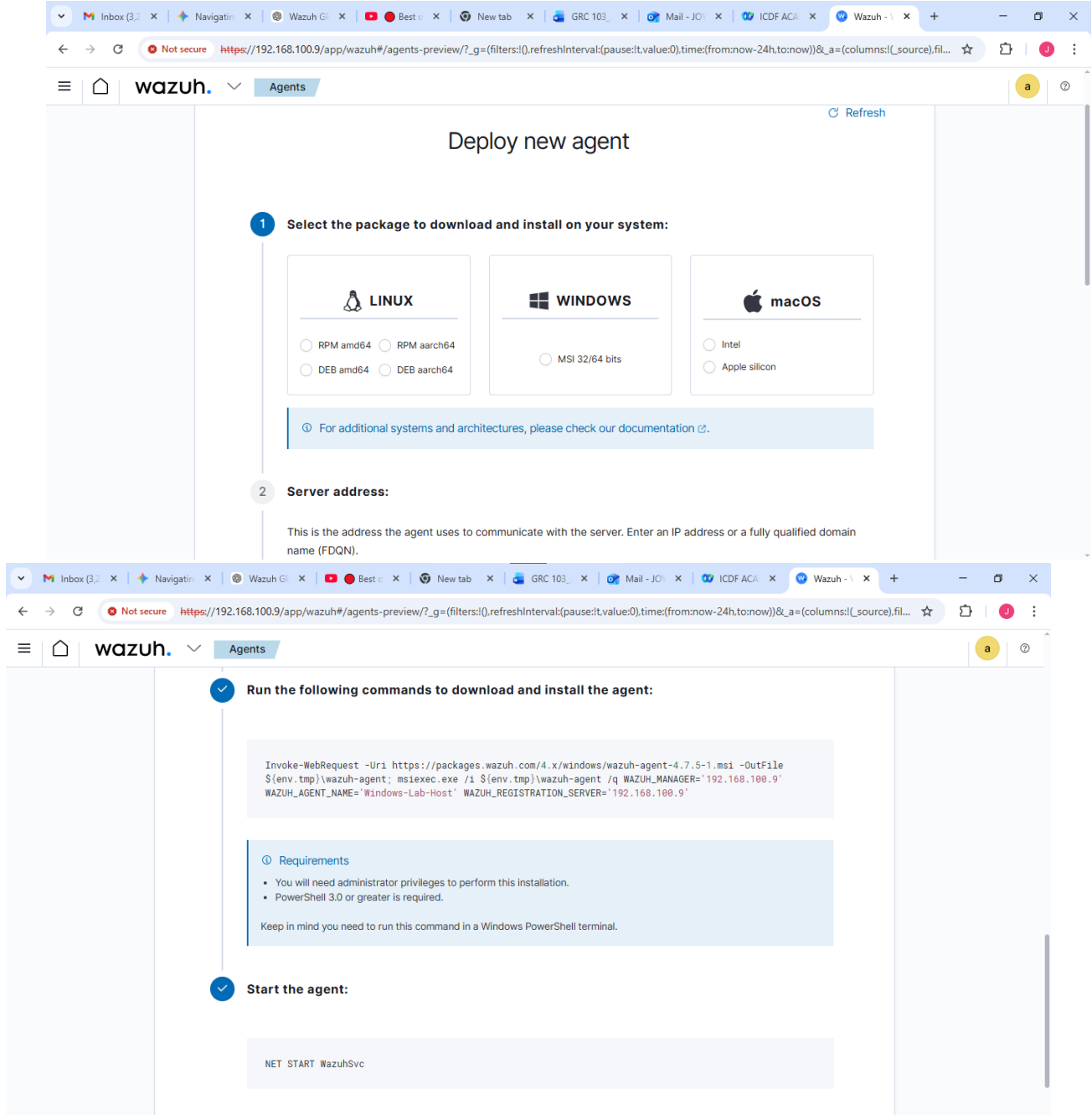
1. Find your Ubuntu VM's IP address: `ip addr show`
2. Open a web browser and navigate to: `https://192.168.100.9`
3. **Accept the browser security warning.** (This is expected in a lab environment).
4. Log in using the credentials provided at the end of the installation script (default username is admin).



GRC Note: This dashboard serves as your **Risk & Control Monitoring Console**. It provides the evidence needed for compliance audits and ongoing risk assessments.

7. Part 3: Installing the Wazuh Agent (Windows)

1. On your **Windows host**, download the Wazuh Agent MSI installer:
<https://packages.wazuh.com/4.x/windows/wazuh-agent-4.12.0-1.msi>
2. Run the MSI file and install it with the default settings.



The screenshot displays the Wazuh web interface, specifically the 'Agents' section. The main heading is 'Deploy new agent'. Below this, there are two numbered steps:

- 1 Select the package to download and install on your system:**
 - LINUX:** Options include RPM amd64, RPM aarch64, DEB amd64, and DEB aarch64.
 - WINDOWS:** Option is MSI 32/64 bits.
 - macOS:** Options include Intel and Apple silicon.
 - A link for additional systems and architectures is provided.
- 2 Server address:**

This is the address the agent uses to communicate with the server. Enter an IP address or a fully qualified domain name (FQDN).

Below the server address, there is a section titled 'Run the following commands to download and install the agent:' which contains a PowerShell command to download the MSI file and install it. Below this, there is a 'Requirements' section listing the necessary privileges and PowerShell version. Finally, there is a 'Start the agent:' section with a command to start the Wazuh service.

```
Invoke-WebRequest -Uri https://packages.wazuh.com/4.x/windows/wazuh-agent-4.7.5-1.msi -OutFile $(env:tmp)\wazuh-agent; msisexec.exe /i $(env:tmp)\wazuh-agent /q WAZUH_MANAGER="192.168.100.9" WAZUH_AGENT_NAME="Windows-Lab-Host" WAZUH_REGISTRATION_SERVER="192.168.100.9"
```

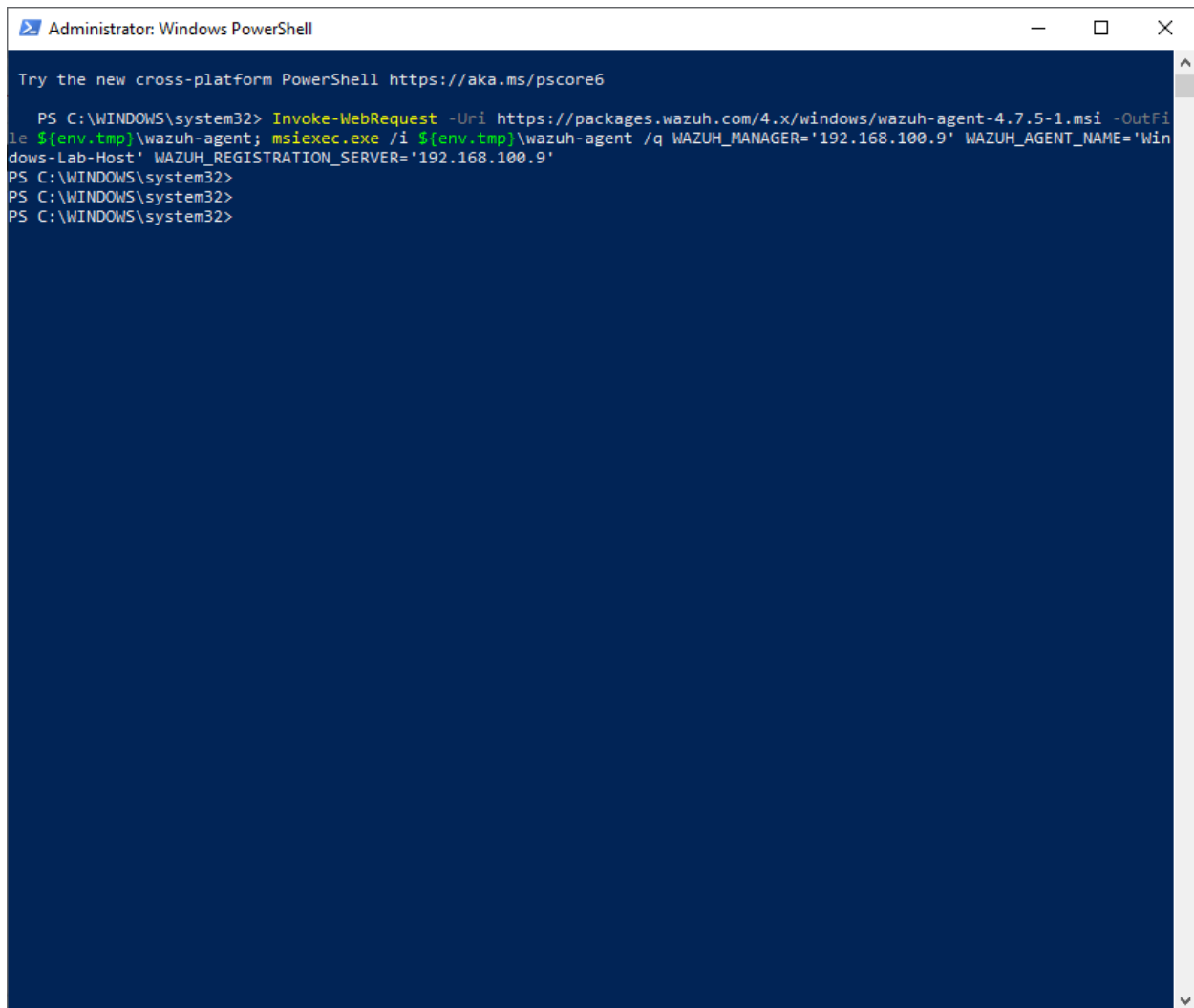
Requirements

- You will need administrator privileges to perform this installation.
- PowerShell 3.0 or greater is required.

Keep in mind you need to run this command in a Windows PowerShell terminal.

Start the agent:

```
NET START WazuhSvc
```



```
Administrator: Windows PowerShell

Try the new cross-platform PowerShell https://aka.ms/powershell

PS C:\WINDOWS\system32> Invoke-WebRequest -Uri https://packages.wazuh.com/4.x/windows/wazuh-agent-4.7.5-1.msi -OutFile $env:tmp\wazuh-agent; msexec.exe /i $env:tmp\wazuh-agent /q WAZUH_MANAGER='192.168.100.9' WAZUH_AGENT_NAME='Windows-Lab-Host' WAZUH_REGISTRATION_SERVER='192.168.100.9'
PS C:\WINDOWS\system32>
PS C:\WINDOWS\system32>
```

8. Part 4: Agent-Manager Registration

1. Generate Agent Key on Manager

On your **Ubuntu VM terminal**, run:

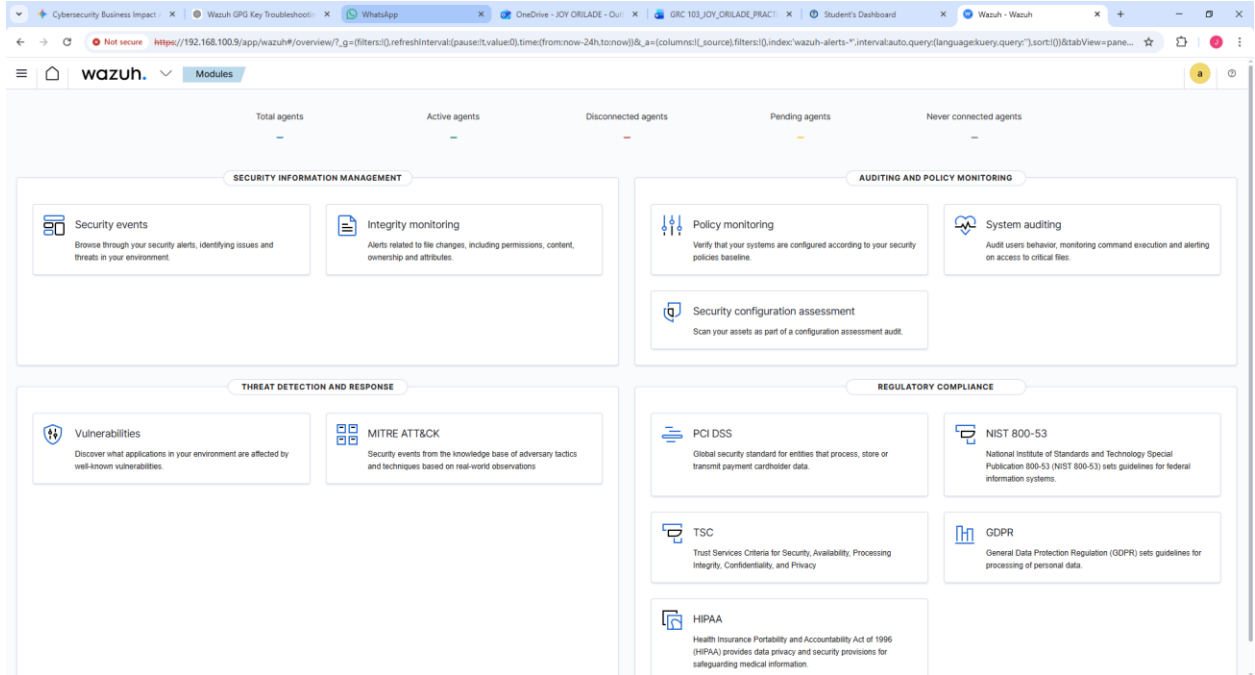
```
bash
```

```
sudo /var/ossec/bin/manage_agents
```

- Press A to **Add an agent**.
- Enter a name (e.g., Finance-Dept-Workstation).
- For the IP address, you can leave it as any.
- Confirm and then press E to **Extract the key**.
- **Copy the generated key**.

2. Apply Key in the Windows Agent

1. On your **Windows host**, open the **Wazuh Agent Manager**.
2. Go to the **Management** tab.
3. Paste the key into the "Agent key" field.



4. In the "Manager address" field, enter the IP address of your **Ubuntu VM**.
5. Click **Apply** and then **Restart**.

Verification: Go to the Wazuh Dashboard > **Agents**. You should soon see your agent with a green **Active** status.

9. Part 5: Implementing a Detective Control (File Integrity Monitoring)

We will now configure the **detective control** to monitor for the identified risk.

1. Edit Agent Configuration

1. On your **Windows host**, navigate to C:\Program Files (x86)\ossec-agent\.
2. Open the ossec.conf file as Administrator.
3. Find the <syscheck> section.
4. Add the following line (replace abc with your Windows username):

xml

```
<directories realtime="yes">C:\Users\AMINU IDRIS\SensitiveFiles</directories>
```

2. Restart the Agent

Restart the Wazuh agent from the **Wazuh Agent Manager** GUI or via `services.msc`.

10. Part 6: Risk Monitoring & Control Verification

Now, you will verify that your control is operating effectively and generate risk-related events.

1. **Create the Monitored Folder:** Create `C:\Users\abc\SensitiveFiles` on your Windows machine.
2. **Simulate a Risk Event:** Perform these actions in the `SensitiveFiles` folder to simulate unauthorized activity:
 - | Create a new file (`Q4_Financial_Forecast.docx`).
 - | Modify the file by adding text.
 - | Delete the file.
3. **Monitor Control Effectiveness in the Dashboard:**
 - | Go to the Wazuh Dashboard.
 - | Navigate to **Security Events**.
 - | Filter for `rule.groups: "syscheck"` to see only File Integrity Monitoring alerts.
 - | Click on alerts to see details: file path, action (added/modified/deleted), timestamp, and file checksums.

11. GRC Workshop & Analysis Questions

Answer the following questions in your lab report, connecting the technical exercise to GRC principles.

1. **Risk Identification & Analysis:** In the context of our scenario, the risk was "unauthorized modification of financial documents."
 - | What is the potential **business impact** (e.g., financial, reputational, operational) if this risk were realized?
 - | Based on the alerts you generated, how does this control help in **quantifying** the risk (e.g., frequency of events)?

ANSWER:

Risk Identification & Analysis

- **Business Impact:** Unauthorized modification of financial forecasts can lead to **financial loss** through poor strategic decisions, **reputational damage** if external stakeholders lose trust in the data, and **operational disruption** as teams must pause to verify the integrity of all financial records.

- **Quantifying Risk:** This control provides data on the **frequency of events** and the **velocity of unauthorized changes**. By seeing how many times Q4_Financial_Forecast.docx was touched over a week, you can transition from an "estimated" risk to a data-driven "actual" risk level.
2. **Control Evaluation & Treatment:** The implemented FIM is a **detective control**.
- What would be a complementary **preventive control** for this same risk?
 - Explain a situation where the alert from this detective control would trigger a **corrective control** (a response action).

ANSWER:

- **Preventive Control:** A complementary control would be **Role-Based Access Control (RBAC)** or **NTFS Permissions**. While FIM (detective) tells you a file was changed, RBAC prevents unauthorized users from opening or editing the file in the first place.
- **Corrective Control:** If the FIM alert detects a deletion of the financial forecast, it triggers the **Incident Response Plan** (corrective). A specific corrective action would be restoring the file from the last known good **backup** to return the system to its required state.

3. **Risk Monitoring & Reporting:**

- If you had to report on the **operational effectiveness** of this FIM control to a manager, what three key metrics would you pull from the Wazuh dashboard?
 - How does centralizing this monitoring data, as opposed to checking logs on each individual computer, improve the **governance** and **auditability** of the risk management program?

ANSWER:

To report on **operational effectiveness**, pull these three metrics:

1. **Mean Time to Detection (MTTD):** How quickly the alert appeared after the change was made.
2. **Top Files Modified:** Identifying which sensitive files are targeted most frequently.
3. **Unauthorized Access Attempts:** The ratio of "Added" or "Deleted" events versus "Modified" events by non-authorized users.

Centralization improves governance because it creates a **Single Source of Truth**. Instead of logging into ten different Windows machines (which is inefficient and prone to tampering), an auditor can view one immutable dashboard. This ensures the **Audit Trail** is complete and centralized for faster compliance verification.

4. **Compliance Mapping:** Many regulations (like SOX, PCI DSS, HIPAA) require monitoring critical files for changes.
- } How does a tool like Wazuh provide **evidence** for compliance audits?
 - } Briefly describe how you would use the Wazuh dashboard to demonstrate to an auditor that a specific sensitive file has not been altered during a defined period (e.g., last quarter).

ANSWER:

- **Evidence for Audits:** Wazuh provides **cryptographic proof** (checksums) that a file's content is identical to its original state. For regulations like PCI DSS, these logs serve as a permanent record that monitoring was active.
- **Demonstrating Integrity:** To show an auditor that a file has not been altered, you would use the **Dashboard > Security Events** tab, filter by the specific file path, and set the time range to "Last Quarter." A "No results found" report for that file path proves that no unauthorized modifications occurred during that audit period.